Seguridad del sistema antirrobo IoT (ISO 27400)

Objetivo y alcance

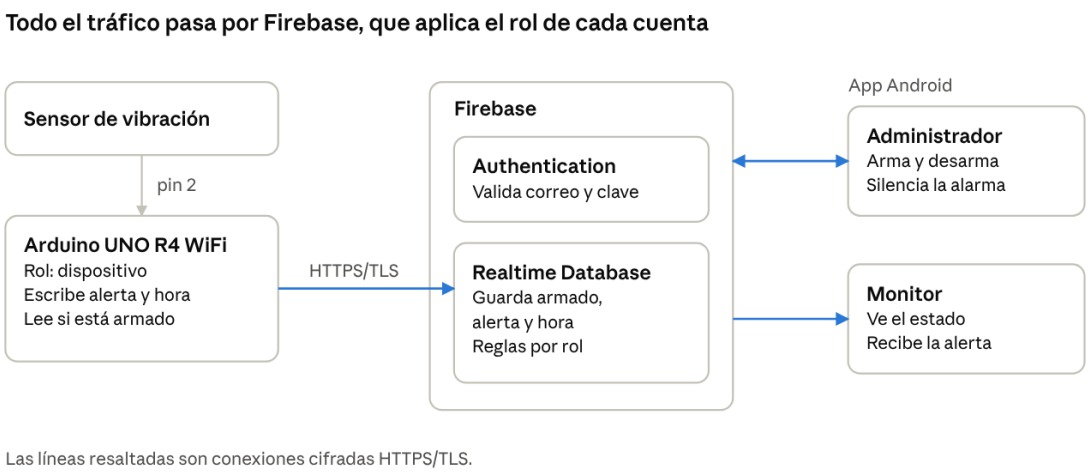
El sistema protege el acceso y el control del antirrobo con autenticación, permisos por rol y comunicaciones cifradas. Este documento describe cada medida, cómo se verifica y qué riesgos quedan abiertos.

Alcance: la app Android (Kotlin), Firebase Authentication, Firebase Realtime Database y el Arduino UNO R4 WiFi con su sensor de vibración.

Referencias: ISO/IEC 27400 (seguridad en IoT), el Anexo A de ISO/IEC 27001:2022 (control de acceso, autenticación y criptografía) y los requisitos fundamentales de IEC 62443 para entornos OT (identificación y autenticación, control de uso, confidencialidad de los datos). Se citan como referencia, y se pueden contrastar con el material del curso.

Arquitectura y flujo de datos

Todo el tráfico pasa por Firebase, que aplica el rol de cada cuenta antes de leer o escribir.



arquitectura · sensor, Arduino, Firebase y dos apps

El administrador lee y escribe; el monitor solo lee. El Arduino escribe la alerta y la hora, y lee si el sistema está armado.

Medidas de seguridad implementadas

Se aplican 12 medidas en cuatro frentes: identidad, control de acceso, comunicaciones y manejo de secretos.

#	Medida	Referencia	Implementación	Cómo se verifica
1	Autenticación de usuarios	ISO 27001 A.8.5 · IEC 62443 FR1	Login con correo y contraseña en Firebase Authentication. El error es genérico ("Correo o contraseña incorrectos") y no revela cuál dato falló.	Probar una contraseña incorrecta y un correo inexistente.
2	Protección de credenciales	ISO 27001 A.5.17 · ISO/IEC 27400	La app no guarda contraseñas ni las lleva fijas en el código. Firebase las almacena como hash en sus servidores.	Revisar el código de la app y ver que la consola solo lista correos.
3	Validación de datos de entrada	ISO 27001 A.8.26	El correo debe tener formato válido y la contraseña al menos 6 caracteres antes de enviarse.	Probar un correo mal escrito y una clave corta.
4	Control de acceso por rol	ISO 27001 A.5.15 y A.5.18 · IEC 62443 FR2	Tres roles: administrador (arma, desarma, silencia), monitor (solo lee) y dispositivo (el Arduino). El monitor no ve la pestaña Control.	Entrar como monitor y comprobar que no aparece Control.
5	Control de acceso aplicado en el servidor	ISO 27001 A.8.3	Las reglas de Realtime Database rechazan escrituras de quien no tiene el rol, aunque alguien altere la app.	Zona de pruebas de reglas: escritura de un monitor en /sistema/armado debe ser rechazada.
6	Mínimo privilegio del dispositivo	IEC 62443 FR2	La cuenta del Arduino solo escribe alerta y hora. No puede armar ni desarmar.	Zona de pruebas de reglas: escritura del dispositivo en /sistema/armado rechazada.
7	Sin escalada de privilegios	ISO 27001 A.5.18	Una cuenta nueva solo puede crear su perfil como monitor. Los roles de administrador y dispositivo se asignan a mano en la consola.	Crear una cuenta nueva y ver que queda como Monitor.
8	Sin acceso anónimo	ISO 27001 A.8.3	Las reglas exigen sesión iniciada para leer cualquier dato. Se reemplazaron las reglas de prueba, que vencen en diciembre.	Zona de pruebas de reglas: lectura sin autenticar rechazada.

#	Medida	Referencia	Implementación	Cómo se verifica
9	Comunicaciones cifradas	ISO 27001 A.8.24 y A.8.20 · IEC 62443 FR4	La app y el Arduino hablan con Firebase por HTTPS/TLS, puerto 443. El Arduino usa una conexión segura (WiFiSSLClient).	Revisar en el código del Arduino la conexión SSL al puerto 443.
10	Integridad de la hora de la alerta	IEC 62443 FR3	La hora de cada alerta la asigna el servidor de Firebase, no el dispositivo ni la app.	Golpear el sensor y comparar la hora mostrada con la hora real.
11	Secretos fuera del repositorio	ISO 27001 A.8.9	arduino_secrets.h (WiFi, API key y clave del dispositivo) y google-services.json están en el .gitignore.	Revisar en GitHub que esos archivos no estén.
12	Cierre de sesión	ISO 27001 A.8.5	El botón Cerrar sesión elimina la sesión y deja de leer los datos.	Cerrar sesión y comprobar que la app vuelve al login.

Pruebas de verificación

Cinco de las 11 pruebas ya se hicieron con el sistema funcionando. Las otras seis se hacen con la zona de pruebas de reglas de Firebase, en la app y al subir el repositorio.

#	Caso	Pasos	Resultado esperado	Estado
1	Contraseña incorrecta	Ingresar con un correo registrado y otra clave.	Mensaje "Correo o contraseña incorrectos."	Verificado
2	Correo con formato inválido	Escribir un correo sin arroba o sin dominio.	Mensaje que pide un correo válido, sin consultar a Firebase.	Verificado
3	Contraseña corta	Crear una cuenta con una clave de 5 caracteres.	Mensaje que pide al menos 6 caracteres.	Por verificar
4	Cuenta nueva queda como monitor	Crear una cuenta y abrir Perfil.	Rol "Monitor" y sin pestaña Control.	Verificado
5	El administrador controla el sistema	Armar, desarmar, silenciar y simular desde la cuenta administrador.	Los cambios se ven en el otro celular en tiempo real.	Verificado
6	Escritura de un monitor rechazada	Zona de pruebas de reglas: escribir en /sistema/armado con un usuario monitor.	Acceso denegado.	Por verificar

#	Caso	Pasos	Resultado esperado	Estado
7	Lectura sin sesión rechazada	Zona de pruebas de reglas: leer /sistema sin autenticar.	Acceso denegado.	Por verificar
8	El dispositivo no puede armar	Zona de pruebas de reglas: escribir en /sistema/armado con la cuenta del dispositivo.	Acceso denegado.	Por verificar
9	El dispositivo envía alertas	Golpear el sensor con el sistema armado.	El Monitor Serie muestra "Alerta enviada, códigos: 200 / 200" y la app muestra la alerta.	Verificado
10	Cierre de sesión	Perfil, luego Cerrar sesión.	La app vuelve al login.	Por verificar
11	Secretos fuera del repositorio	Abrir el repositorio en GitHub.	No están arduino_secrets.h ni google-services.json.	Por verificar

Riesgos residuales y mejoras

Quedan seis riesgos conocidos. Ninguno impide el funcionamiento y cada uno tiene una mejora posible.

Riesgo	Mejora posible
Las credenciales del Arduino (WiFi y cuenta del dispositivo) viven dentro de su programa. Quien tenga acceso físico a la placa podría extraerlas.	Mantener la cuenta del dispositivo con permisos mínimos (ya aplicado) y cambiar su clave de forma periódica.
La contraseña exige solo 6 caracteres y no hay segundo factor de autenticación.	Exigir una clave más larga y activar la verificación en dos pasos.
No hay registro de auditoría: no queda constancia de quién armó o desarmó el sistema y cuándo.	Guardar un historial de acciones con usuario y hora.
La conexión del Arduino depende de los certificados raíz del firmware de la placa; no se fija un certificado concreto.	Fijar el certificado del servidor en el programa del Arduino.
Las notificaciones llegan solo si la app está abierta o en segundo plano.	Enviarlas con Firebase Cloud Messaging desde un servidor.
El texto "Dispositivo: Conectado" de la pantalla Estado es fijo y no refleja el estado real del Arduino.	Que el Arduino envíe una señal periódica y la app muestre si está conectado.